

Pre-interview project: Vulnerability & Configuration Management

Sep 27, 2026 · @Oskar Mathiasen

About this project

Four sample work tasks, one per responsibility in JYSK's Security Specialist (Vulnerability & Configuration Management) listing, to test whether the day-to-day work is appealing before investing in a career pivot.

Task	Listing bullet	Status
1. VM program review	Maintaining and improving the vulnerability management program	Brief and dataset ready
2. Remediation follow-up	Follow-up on remediation efforts	Not written yet
3. Configuration review	Reviewing configurations for security weaknesses and providing remediation guidance	Not written yet
4. Communicating technical information	Communicating technical information with technical and non-technical colleagues	Not written yet

The company in the scenarios is fictional but modelled on a large Nordic retailer. The datasets are synthetic but use real CVE identifiers, so enrichment with public data (CISA KEV, FIRST EPSS) works as it would on the job.

Each dataset comes with a separate answer-key file listing the planted problems. Open it only after finishing your own analysis. Keep a short log of which parts energised you and which drained you; that log is the real output of the exercise.

Task 1 — VM program review

Diagnose why the vulnerability numbers are meaningless, design a better prioritization, and propose program changes to a steering committee in four weeks.

Scenario

You joined the IT Security team at Norvik Home A/S, a fictional Nordic home-furnishing retailer, three weeks ago. The data covers HQ (data centre and DMZ), an Azure tenant, 160 stores in Denmark, Sweden, Norway and Finland, and about 700 employee laptops. Laptops and store PCs run a scanner agent; everything else is network-scanned weekly.

The September report shows 14,079 open findings and 17.9% SLA compliance. The scanner dashboard reports just over one million "vulnerability instances", a figure someone put on a board slide. Your manager says: *"Infrastructure says the numbers are meaningless and nobody reads the report anymore. The steering committee meets in four weeks. I want a proposal for fixing the program."*

Materials

File	Contents
findings.csv	35,011 scanner findings (open, plus fixed in the last six months), one row per asset × plugin
plugins.csv	Plugin name, severity and max CVSS per plugin
plugin_cves.csv	Plugin → CVE mapping with per-CVE CVSS v3; all CVE IDs are real
scanner_assets.csv	The scanner's view of assets: last seen, credentialed-scan status
cmdb_assets.csv	The CMDB's view: owner team, criticality, environment, internet exposure, retired status
exceptions.csv	The risk-acceptance register
VM_standard_and_september_report.md	Current policy excerpt and the September report, including how its metrics are computed

You fetch the enrichment data yourself: the CISA KEV catalog and FIRST EPSS scores. Several realistic problems are planted in the data. The answer key lists them; open it only when you are done.

Deliverables

1. **Diagnosis.** What the 14,079 and the million are actually made of. Separate real risk from artefacts, and find where the data *hides* risk rather than inflating it.
2. **Prioritization scheme.** A replacement for CVSS-only severity that a sysadmin can apply without a spreadsheet. Show how the backlog re-sorts under it and what your top 10 actions are.
3. **Program changes.** Revised deadlines, one or two coverage KPIs, a better exception process, and a reporting format per owner team.
4. **Two written pieces.** A one-page memo for the steering committee (non-technical readers, decisions first). A half-page reply to the Head of Infrastructure, who believes security "just generates noise".

Time budget

About 10–15 hours. Expect half of it on joining and cleaning data; the hostname formats differ between CMDB and scanner on purpose.

What to notice about yourself

- Did the data cleaning feel like detective work or like drudgery?
- Did designing the prioritization rule feel like a real problem, or like arbitrary line-drawing?
- How did writing the reply to the sceptical infrastructure lead feel? That kind of persuasion is a large share of the real job.

Task 2 — Remediation follow-up

Not written yet. Planned to reuse the Norvik dataset: chasing specific owner teams on overdue items, handling pushback, and verifying claimed fixes.

Task 3 — Configuration review

Not written yet. Planned around real configuration files (for example a web server's TLS settings, an SSH daemon config and a firewall policy excerpt) reviewed against a benchmark such as CIS. This is where cryptography knowledge is most directly useful.

Task 4 — Communicating technical information

Not written yet. Planned as explaining one technical finding to three audiences: the sysadmin who must fix it, a store manager affected by the downtime, and a non-technical executive.

Reference material

For Task 1, use KEV and EPSS as of the export date (2026-09-21), not today's versions; otherwise later additions change your priorities.

Resource	What it is	Where
CISA KEV catalog	CVEs confirmed exploited in the wild, with date added and known ransomware use. The JSON version is easiest to join.	cisa.gov
FIRST EPSS	Probability of exploitation in the next 30 days, per CVE. Daily files follow the pattern <code>epss_scores-YYYY-mm-dd.csv.gz</code> .	first.org
CVE List V5	Official CVE records, including CNA-provided CVSS scores. The dataset's per-CVE scores come from here.	GitHub
CISA SSVC	Decision-tree approach to vulnerability prioritization; good to agree or argue with in deliverable 2.	Search "CISA SSVC"
CIS Controls v8, Control 7	Continuous Vulnerability Management: a short, widely used baseline for what a program should contain.	Search "CIS Controls v8"
Greenbone Community Edition, Nessus Essentials	Free scanners for a home lab against a deliberately vulnerable VM, to see raw scanner output first-hand.	Vendor sites